

Anexo: integridad de los datos de evaluación (experimento P2)

Este anexo documenta un control de integridad **aparte** del pipeline de detección de secretos. No sustituye a Gitleaks ni al LLM: comprueba que las métricas de evaluación no se puedan falsear alterando el fichero de falsos positivos.

Objetivo

El LLM se evalúa sobre `fp_candidates.json` (1.128 filas etiquetadas como F o X en CredData). Las tasas de acierto (34 % frente a 99 %) dependen de que esas etiquetas sean las correctas.

Si se altera ese fichero —sin modificar el modelo ni Gitleaks—, las cifras dejan de ser válidas. En este experimento, el envenenamiento de datos (*data poisoning*) no ataca los pesos del LLM: ataca **el dataset con el que se mide**.

Método

1. Se construyó un manifiesto de confianza del fichero limpio (`trust_baseline.json`): hash SHA-256, número de filas (1.128) y un subconjunto de control de 7 claves (*golden set*). 2. Se simularon ataques en laboratorio sobre copias del fichero: - **Inyección de filas**: se añaden líneas sintéticas etiquetadas como secreto real (T) dentro del conjunto de FP. - **Volteo de etiquetas**: se cambia F/X → T en un porcentaje de filas. El número total de filas no varía; el ataque es más difícil de ver por recuento. 3. Se aplicaron detectores sobre el fichero resultante.

Detectores

Id	Señal	Función
D1	Hash del fichero	Detecta cualquier cambio respecto al manifiesto
D2	Subconjunto dorado	Detecta alteraciones en las 7 filas de control
D3	Recuento	Detecta cambios en el número de filas (esperado: 1.128)
D4	PSI (deriva de etiquetas)	Detecta cambios en la proporción F/T (umbral 0,2)
D5	Marcadores de laboratorio	Campos <code>_poison_*</code> insertados por el script de ataque (solo en este experimento)

Resultados

Matriz sobre los 1.128 FP de CredData:

Ataque	Veneno	¿Detectado?	Observación
Control	0 %	No	El fichero limpio no genera alertas
Inyección de filas	5 % (+56 filas)	Sí	Alertan D1, D3, D4 y D5
Volteo de etiquetas	5 % (56 filas)	Sí	D3 no alerta (sigue habiendo 1.128 filas); D1 y D4 sí
Volteo de etiquetas	30 %	Sí	También alerta D2: el veneno alcanza el subconjunto de control

Ataque	Veneno	¿Detectado?	Observación
Volteo de etiquetas	1 % (11 filas)	Parcial	D4 queda bajo el umbral (PSI 0,09). D1 sí alerta si existe manifiesto previo

El volteo de etiquetas es el ataque más sigiloso, porque no cambia el volumen del dataset. A partir del 5 % de filas modificadas, el hash (D1) y la deriva estadística (D4) bastan. Con el 1 %, sin manifiesto previo la detección queda incompleta.

Este control no forma parte del detector de secretos; protege la fiabilidad de la evaluación. Los scripts de reproducción son `build_trust_baseline.py`, `inject_data_poison.py` y `detect_data_poison.py`.